



리눅스 OS 보안설정 가이드



2024년 9월 21일 인사총무팀 홍성원이 인수인계를 위해 작성함.

1. 로케일 및 타임존 설정

- **로케일 설정:** 서버에서 사용하는 언어와 문자 인코딩을 설정하는 것으로, 시스템에서 발생하는 로그와 에러 메시지를 관리할 때 중요합니다. UTF-8을 사용하는 것은 다양한 문자 지원 및 호환성을 보장하기 위함입니다.
- **타임존 설정:** 서버의 시간대를 맞춰 두면 로그 기록, 파일 생성 시간, 작업 일정 등이 정확하게 동기화됩니다. 특히 여러 지역에 서버가 있는 경우 시간을 통일하여 관리하는 것이 중요합니다.

2. KVM Disk 마운트

- KVM(Kernel-based Virtual Machine)은 가상화 기술로, 가상 머신의 디스크를 서버에 마운트하여 사용할 수 있도록 하는 작업입니다. 이는 물리적 하드웨어 리소스를 효율적으로 사용할 수 있게 하고, 서버 관리 및 자원 배분을 용이하게 합니다.
- 추가 디스크를 마운트하여 데이터를 저장하거나 백업, 로그 등을 분리하는 것이 성능 및 안정성에 유리합니다.

3. 패키지 설치 및 yum 설정

- 서버 운영에 필요한 필수 패키지를 설치하고, 저장소 설정을 사내 네트워크 내의 미러 서버로 변경하는 작업입니다. 외부 저장소를 사용하는 경우 보안 위협이 있을 수 있고, 네트워크 속도 문제도 발생할 수 있어 내부 저장소를 사용하는 것이 더 안전하고 빠릅니다.
- 주요 패키지 설치: 서버가 안정적이고 성능 좋게 운영되도록 하는 기본 설정입니다.

4. 불필요 계정 삭제

- 시스템에 기본으로 생성된 불필요한 계정들은 보안 취약점이 될 수 있습니다. 악의적인 사용자가 접근할 수 있는 계정이 존재하면 시스템이 해킹될 위험이 커지므로, 필요 없는 계정을 삭제하는 것은 보안 강화에 필수적입니다.

5. 서비스 계정 및 권한 설정

- **계정 그룹 및 권한 관리:** 서버에서 작업하는 사용자의 역할을 분리하고 각 그룹에 적절한 권한을 부여하는 것은 보안상의 중요한 요소입니다. 예를 들어, `wheel` 그룹은 관리자 권한을 가진 계정만 속하게 하고, 일반 사용자는 이 권한에 접근할 수 없게 해야 합니다.
- **서비스 데몬 계정:** 특정 서비스(예: Apache HTTPD)를 실행하는 데 전용 계정을 사용하는 것은 보안 및 관리상의 이점을 제공합니다. 이렇게 하면 서비스 간의 권한이 겹치지 않도록 하여 보안을 강화하고, 각 서비스의 로그와 데이터를 독립적으로 관리할 수 있습니다.

6. SELinux 비활성화

- **SELinux**는 시스템 보안을 강화하기 위한 접근 제어 메커니즘이지만, 특정 애플리케이션과 호환성 문제가 있거나 설정이 복잡할 경우 비활성화하기도 합니다. SELinux가 설정되어 있지 않으면 시스템에서 불필요한 제약 없이 애플리케이션을 운영할 수 있지만, 보안 정책이 필요하지 않은 환경에서만 비활성화하는 것이 좋습니다.

이러한 작업들은 서버의 보안성과 안정성을 유지하고, 불필요한 서비스나 계정으로 인해 발생할 수 있는 위험을 사전에 차단하며, 서버의 성능을 최적화하는 데 필요합니다. 회사에서는 이러한 항목들을 기본적으로 설정함으로써 서버 운영의 일관성과 안정성을 보장하려는 것입니다.

서버PC 작업 내용

✓ ~~OS 설치 시 등록된 IP 변경 (10.10.33.189)~~

- Terra → [REDACTED]
- Cass → [REDACTED]
- 게이트웨이 [REDACTED]
- DNS 8.8.8.8

```
sudo nmcli con mod <enp2s0> ipv4.addresses [REDACTED]
sudo nmcli con mod enp2s0 ipv4.dns "8.8.8.8,8.8.4.4"
```

#연결 재시작

```
sudo nmcli con down [REDACTED]
```

```
sudo nmcli con up [redacted]
```

#변경사항 확인

```
nmcli dev show | grep DNS
```

✓ 불필요한 계정 삭제

✓ ~~games~~ 삭제 (그룹 및 사용자)

✓ ~~lp~~ 삭제 (그룹 및 사용자)

✓ ~~unbound~~ 삭제 (사용자)

시스템 계정 목록 확인

```
cat /etc/passwd
```

불필요 계정 ~~삭제~~ (예: games, ftp 계정)

```
userdel -r games
```

```
userdel -r ftp
```

계정 삭제 후 남은 홈 디렉토리 및 파일 삭제 확인

```
ls /home
```

~~OS 설치 시 별도 설정 없이 설치하여 기본 사용자가 많이 없는 듯 하다~~

✓ 로케일 및 타임존 설정

로케일을 ~~UTF-8~~로 설정

```
localectl set-locale LANG=ko_KR.UTF-8
```

타임존을 서울로 설정

```
timedatectl set-timezone Asia/Seoul
```

설정된 로케일 및 타임존 확인

```
localectl
```

```
timedatectl
```

✓ 패키지 설치 및 yum 설정

필수 패키지 설치

```
yum install -y vim net-tools wget git
```

```
# yum 캐시 업데이트 및 리포지토리 확인
yum clean all
yum repolist
```

✓ 계정생성

- [redacted]
- [redacted]

✓ 계정생성

- [redacted]
- [redacted]

✓ 계정생성

- [redacted]
- [redacted]

✓ [redacted]

```
sudo usermod -aG wheel [redacted]
sudo usermod -aG wheel [redacted]
```

wheel 그룹이 아닌 사용자가 sudo 명령어 사용 시 출력되는 화면

```
[swhong@localhost ~]$ sudo ls /root
[sudo] swhong의 암호 :
swhong은 (는 ) sudoers 설정 파일에 없습니다. 이 시도를 보고 합니다.
[swhong@localhost ~]$
```

✓ 서비스 설치

```
dnf -y install net-snmp rsyslog sysstat
```

✓ SSHD 취약 알고리즘 비활성화

- 파일 수정 시 커서 "i" 입력

- 작성 후 `esc` → `:` → `wq`
- SSH연결 시 강력한 보안 연결 및 인증 키 제공

```
sudo vi /etc/ssh/sshd_config
```

#파일 하단에 기재

```
# Restrict key exchange, cipher, and MAC algorithms, as per s
KexAlgorithms curve25519-sha256,curve25519-sha256@libssh.org,
Ciphers chacha20-poly1305@openssh.com,aes256-gcm@openssh.com,
MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.
```

설정 저장 후 나감

```
sudo systemctl restart sshd
```

데몬 재실행

#상태확인

```
sudo systemctl status sshd
```

☒ SSH 접속 시 경고문구 표기

```
sudo vi /etc/motd
```

#내용추가 후 저장

```
- W A R N I N G -
```

```
A notice that any unauthorized use of the system is unlawful,
and may be subject to civil and/or criminal penalties.
```

#permitRootLogin

```
sudo vi /etc/ssh/sshd_config
```

#내용수정

```
PermitRootLogin no
```

#데몬 재실행

```
sudo systemctl restart sshd
```

✓ Bash 관련 설정

- 보안 강화 및 시스템 관리 목적

/etc/bashrc 파일 수정

- `export HISTFILESIZE=10000` :
 - Bash에서 명령어 기록 파일(`~/.bash_history`)에 저장할 수 있는 **최대 명령어 개수**를 **10,000개**로 설정. 즉, 오래된 명령이 기록 파일에서 삭제되기 전에 더 많은 기록을 유지.
- `export HISTSIZE=1000` :
 - 현재 세션에서 보관할 명령어 기록의 **최대 개수**를 **1,000개**로 설정. 세션 동안 입력된 명령어들이 이 한도를 넘으면 오래된 기록이 삭제.
- `umask 0022` :
 - 새로운 파일이 생성될 때 기본 파일 권한을 설정하는 값. `0022`는 파일을 생성할 때 **파일은 644 (읽기/쓰기/읽기) 권한을, 디렉터리는 755 (읽기/쓰기/실행) 권한을** 가집니다. 이는 보안성을 유지하면서도 기본적인 읽기/실행 권한을 부여.

Crontab에서 생성하는 파일에 umask 적용

- Crontab 작업에서 생성하는 파일에 동일한 권한 설정을 적용하기 위해 서비스 파일(`/usr/lib/systemd/system/crond.service`)에 `** UMask=0022 *`를 추가. 이를 통해 **crontab** 작업으로 생성되는 파일들도 **644** 권한을 가질 수 있음.
- 변경 후 `systemctl daemon-reload` 와 `systemctl restart crond.service` 를 통해 새로운 설정을 적용

/etc/skel/.bash_logout 파일 수정

- 사용자가 로그아웃할 때의 동작을 설정
- `who -m` : 현재 로그인한 사용자의 정보를 확인.
- `date` : 로그아웃 시간을 기록.
- 이 설정을 통해 **사용자가 언제 로그아웃했는지 기록되며, 로그아웃할 때 명령어 히스토리도 저장**

/etc/profile 파일 수정

- **HISTTIMEFORMAT="%Y-%m-%d %T " :**
 - 명령어 기록(**history**)에 **명령어가 실행된 시간**을 기록합니다. 이렇게 하면 **언제 어떤 명령어가 실행되었는지 추적**할 수 있어 보안 관리에 유리
- **TMOUT=900 :**
 - **900초(15분) 동안 아무런 입력이 없으면 세션을 자동으로 로그아웃**시킵니다. 이는 **세션 보안을 강화**하기 위한 설정

```
sudo vi /etc/bashrc
```

```
#내용추가
```

```
export HISTFILESIZE=10000
```

```
export HISTSIZE=1000
```

```
umask 0022
```

```
#저장 후 종료~
```

```
sudo vi /usr/lib/systemd/system/crond.service
```

```
#[Service] 섹션에 다음 줄 추가
```

```
UMask=0022
```

```
#저장 후 종료~
```

```
#설정 확인
```

```
sudo systemctl daemon-reload
```

```
sudo systemctl restart crond.service
```

```
sudo vi /etc/skel/.bash_logout
```

```
#다음 내용 추가
```

```
# ~/.bash_logout
```

```
echo "# Log-off:" `who -m` " At: "`date +%Y-%m-%d %k:%M:%S`
```

```
who -Hu | awk '{print "# " $0;}' >> $HISTFILE
```

```
/usr/bin/clear
```

```
#저장 후 종료~
```

```
sudo vi /etc/profile
```

내용추가

```
HISTTIMEFORMAT="%Y-%m-%d %T "  
export HISTTIMEFORMAT  
TMOUT=900  
export TMOUT
```

#저장 후 종료

```
#세션 갱신 후 서버에 반영  
source /etc/bashrc  
source /etc/profile
```

☒ IP 변경

```
sudo vi /etc/sysconfig/network-scripts/ifcfg-██████████
```

```
BOOTPROTO=static  
IPADDR=██████████  
NETMASK=██████████  
GATEWAY=██████████  
DNS1=8.8.8.8  
ONBOOT=yes
```

#네트워크 재시작

```
sudo systemctl restart NetworkManager
```

#확인

```
ip addr show enp2s0  
ip route  
cat /etc/resolv.conf
```

☒ 호스트네임 변경


```
sudo vi /etc/hostname
#localhost.localdomain을 삭제하고 **Terra**로 변경

sudo vi /etc/hosts
127.0.0.1    localhost
127.0.1.1    Terra

sudo reboot
```

서버 접속 방법

1. Fortigate 60E 방화벽 정책 설정

- 방화벽 승인 정책 필요 (cass / terra 각각)
- VPN 계정 생성

2. FortiClient 연결

- 원격 게이트웨이 : XXXXXXXXXX
- 포트번호 (사용자 정의 포트번호 체크) XXXXXX

3. Putty 접속

Cass → Host Name : XXXXXXXXXX

포트번호 : XXXX

Terra → Host Name : XXXXXXXXXX

포트번호 : XXXX

4. 계정 정보